

Lab 01 - SQL Injection Vulnerability in WHERE Clause

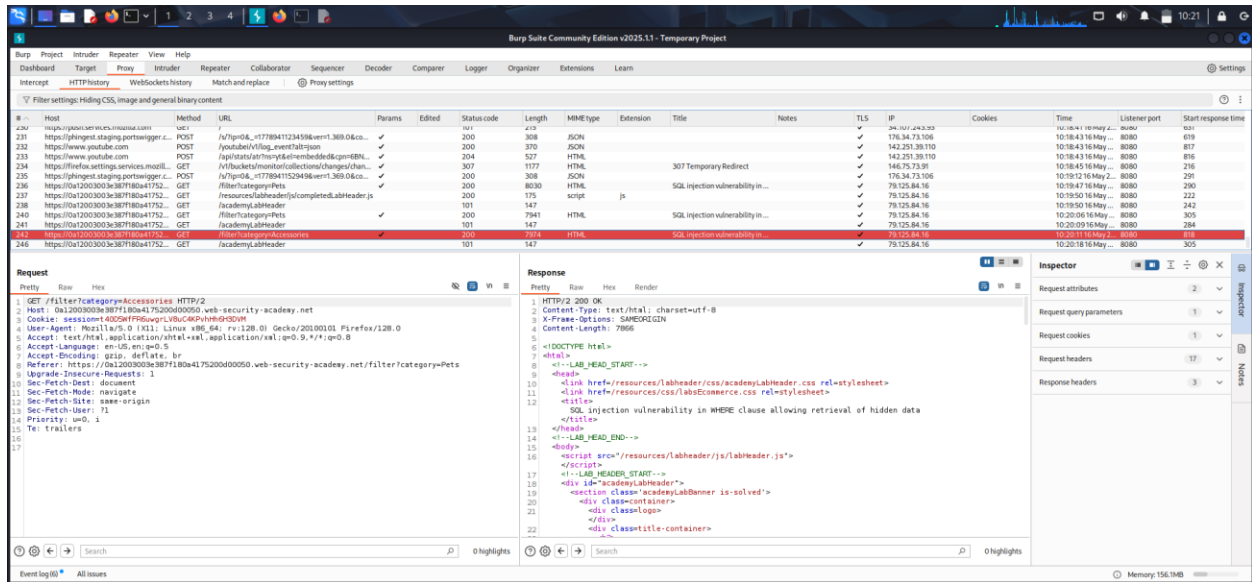


Figure 1 - Navigating to the shop and selecting a category (Accessories) produced the following URL: `/filter?category=Accessories`

The category parameter was passed directly into a backend SQL query with no sanitization a classic injection point.

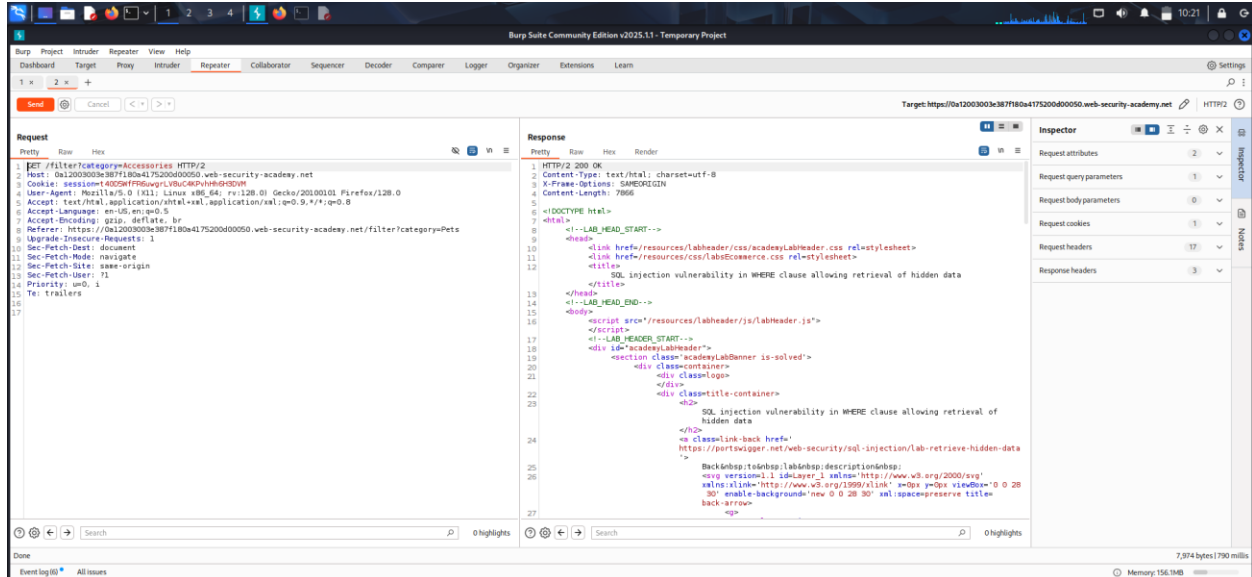


Figure 2 – Send the intercept the request to the Repeater. In the Repeater, click on Send button for the Response. We got 200 OK meaning the request was successful

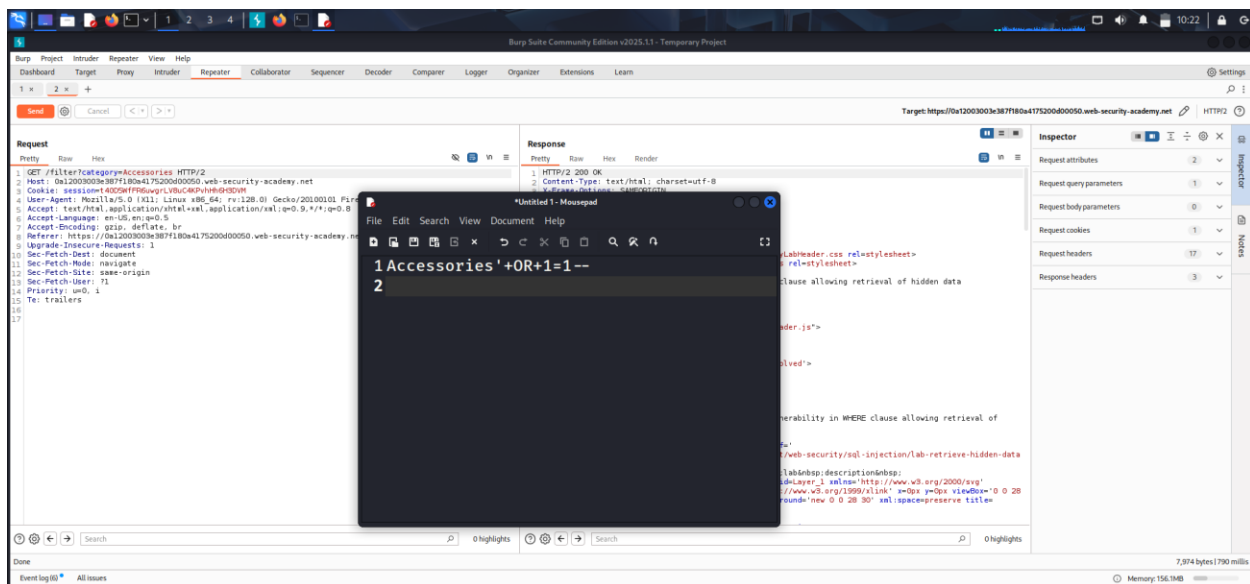


Figure 3 - Payload used: **Accessories'+OR+1=1--**

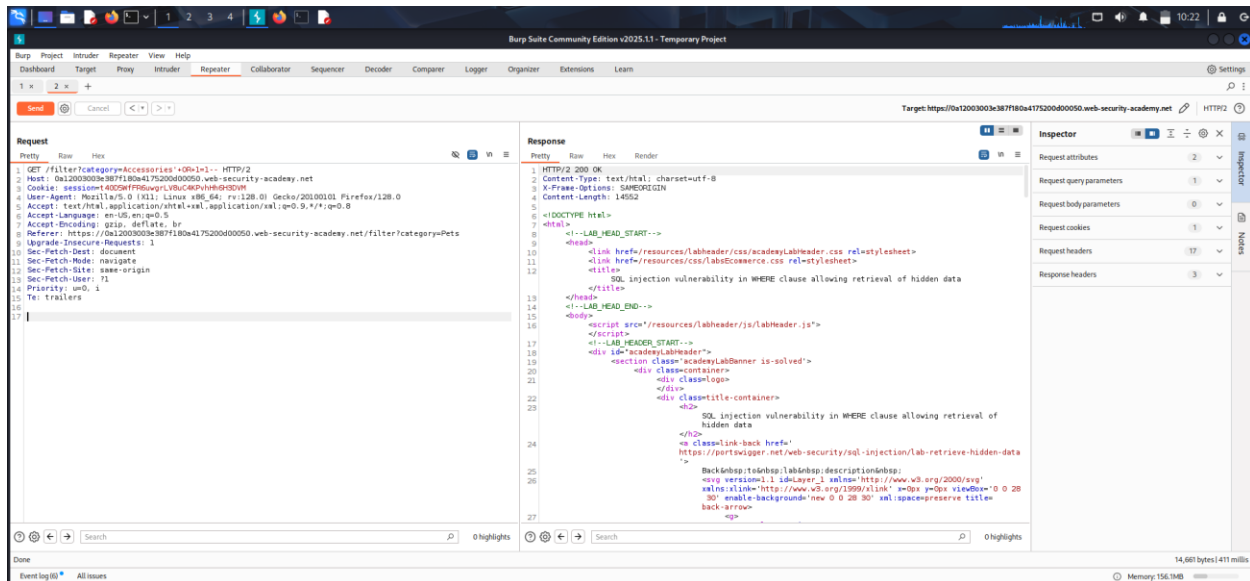


Figure 5 - Request (via Burp Suite Repeater):

GET /filter?category=Accessories'+OR+1=1-- HTTP/2

Host: 0a12003003e387f180a4175200d00050.web-security-academy.net

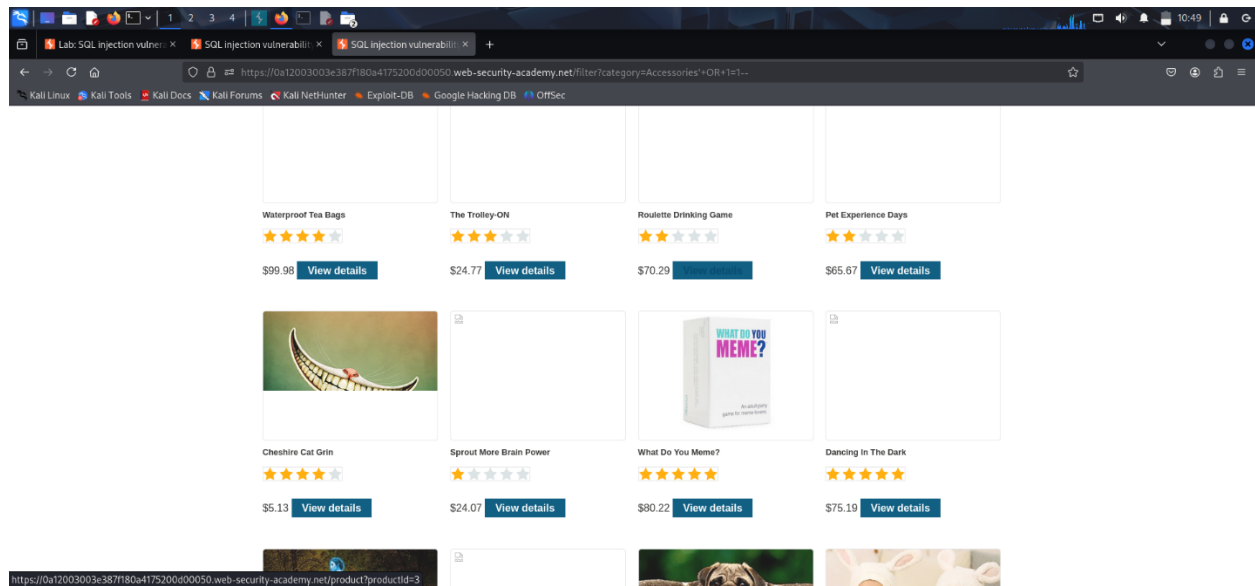


Figure 6 –

OR 1=1 evaluates to true for every row, returning all products. -- comments out the remaining query logic including the released = 1 filter.

Result: All products including hidden/unreleased items were returned.